codigo.sh
SH 1.24KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 4 web pages

Este arquivo é um malware. Especificamente, trata-se de um script de instalação de minerador de criptomoedas (cryptojacking dropper) direcionado a servidores Linux, cujo objetivo é implantar silenciosamente um programa de mineração nos sistemas infectados.

A seguir, a análise passo a passo:

1. Download e execução de payload remoto

O script baixa um pacote comprimido (`fleet_lin.tgz`) de um endereço IP fixo (`http://23.252.123.134:18095/`). Para garantir o sucesso, ele tenta múltiplos métodos: `curl` , `wget` , `python3` e `python` , o que é uma característica típica de scripts de ataque projetados para se adaptar a diferentes ambientes de servidor.

2. Ocultação e persistência

O script cria um diretório oculto em `/tmp/.qc$$` (onde `$$` é o PID do processo) para armazenar os arquivos maliciosos. O uso de diretórios ocultos em `/tmp` é uma técnica clássica para evitar a detecção por administradores ou ferramentas de limpeza automática. Após a descompactação, ele modifica o arquivo `config.json` , substituindo a string `RIGNAME` pelo hostname da máquina infectada, personalizando a configuração do minerador para o alvo.

3. Execução em segundo plano

Utilizando `setsid sh run.sh &` , o script executa o binário malicioso (`run.sh`) em uma nova sessão, desvinculando-o do terminal pai. Isso garante que o processo continue rodando mesmo que o script original seja encerrado ou o usuário faça logout.

4. Verificação do processo

O script aguarda 10 segundos e, em seguida, verifica se os processos `c` ou `x` (localizados no diretório temporário) estão em execução. Isso confirma que o minerador foi iniciado com sucesso.

5. Correlação com infraestrutura maliciosa conhecida

O endereço IP `23.252.123.134` utilizado no script é o mesmo identificado em relatórios de segurança como um servidor de controle (C2) para operações de mineração de criptomoedas. Relatórios indicam que esse IP hospeda o arquivo `fleet_lin.tgz` como parte de um esquema de minerador encoberto, que utiliza diretórios em `/tmp` e APIs de mineração locais . [3]

Conclusão

O comportamento do script (download de IP desconhecido, ocultação em `/tmp` , execução em background, verificação de processos) e a reputação do servidor de origem confirmam que se trata de um **malware do tipo dropper de minerador**. O objetivo é comprometer o servidor para usar seus recursos computacionais na mineração de criptomoedas em benefício do atacante, prejudicando o desempenho do sistema e consumindo energia.

4 web pages

Qual é a categoria principal deste malware?

A categoria principal deste malware é **Cryptojacking** (ou **minerador de criptomoedas** / **coinminer**).

Mais especificamente, ele é um **dropper/loader de minerador** — um script que baixa e implanta um minerador de criptomoedas (provavelmente Monero/XMRig, dado o padrão `config.json` com `RIGNAME`) em servidores Linux comprometidos. As características que confirmam essa categorização:

- **Diretório oculto em** `/tmp` (`.qc$$`) para evasão
- **Download de payload de IP fixo** (`23.252.123.134`)
- **Personalização do** `config.json` com o hostname da vítima (`RIGNAME` → hostname)

- **Execução em background com** `setsid` para persistência
- **Verificação de processos** (`c` ou `x`) para confirmar que o minerador está rodando
- **Uso de múltiplos métodos de download** (curl, wget, python) para maximizar taxa de sucesso em diferentes ambientes

Embora tecnicamente seja um **script shell dropper**, sua finalidade e o payload que carrega o classificam na categoria **Cryptojacking / Coinminer**.